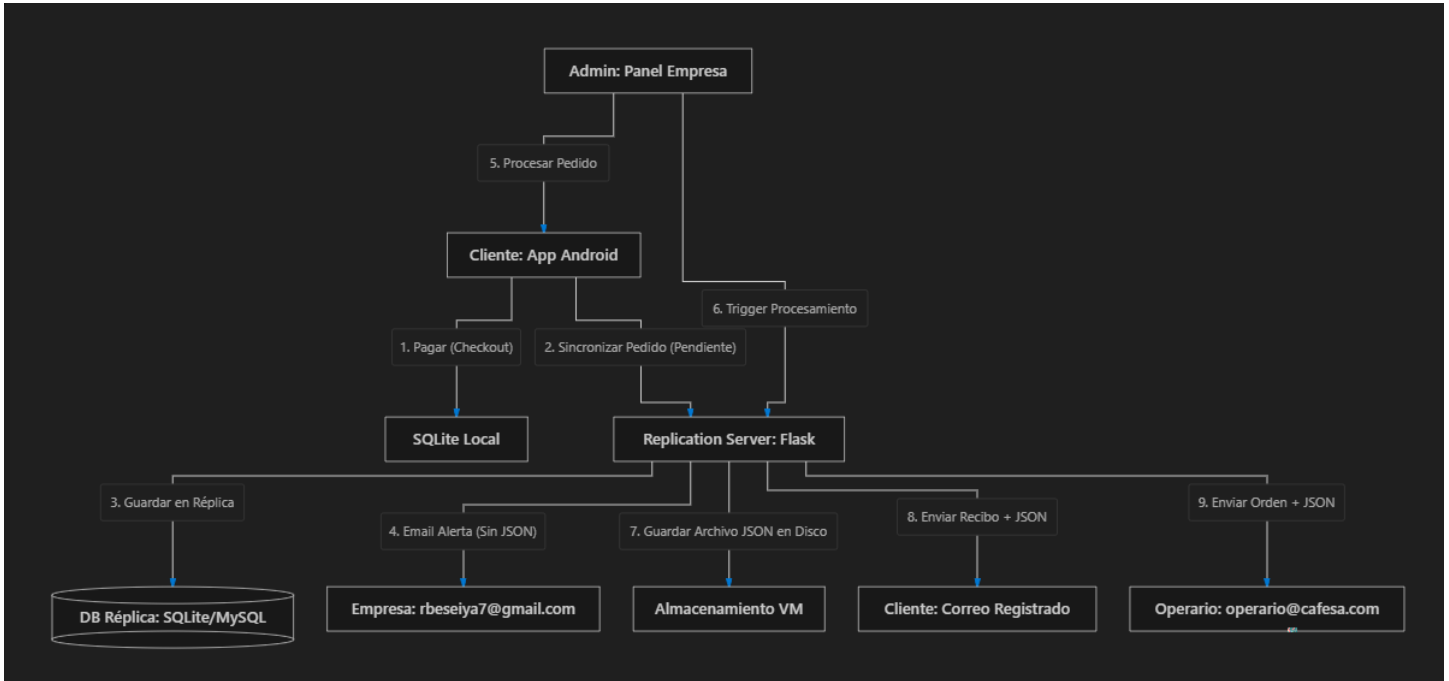


DOCUMENTACION PARCIAL #2

Creación de la Aplicación CHINOS CAFE S.A

Implementamos un flujo de comercio electrónico seguro con base de datos local (SQLite), pasarela de pagos integrada, sincronización en tiempo real mediante polling, replicación en un servidor en la nube/VM, y notificaciones SMTP automáticas.

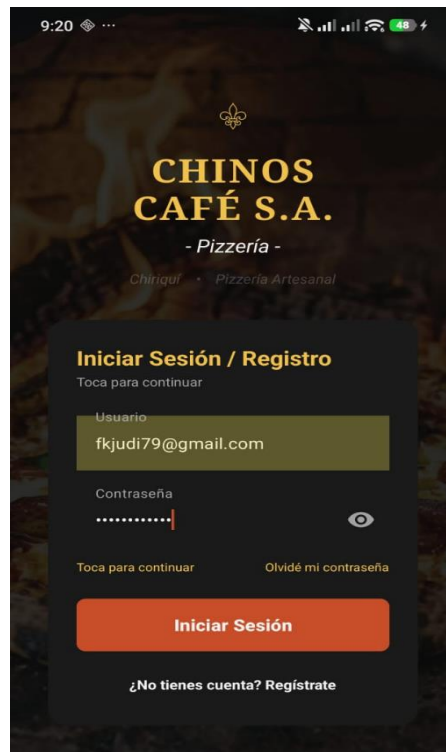


Fase 1: Diseño de la APP

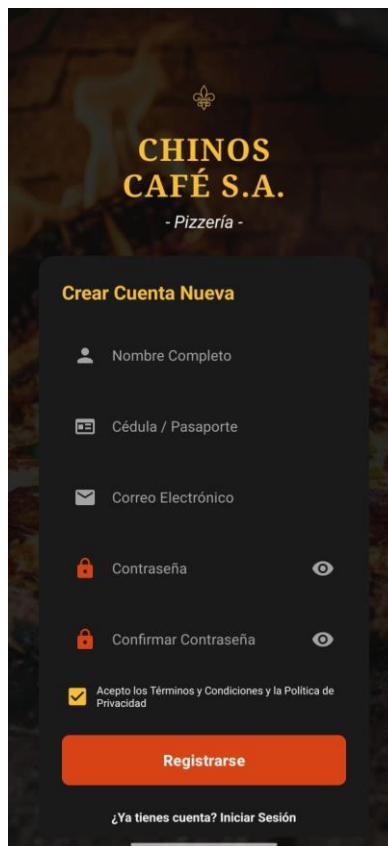
Se diseñó una interfaz gráfica siguiendo las mejores prácticas de experiencia de usuario.

Pantallas de Acceso y Registro:

- **Login:** Fondo del horno de leña gourmet con capa translúcida oscura. El sistema detecta automáticamente el rol del usuario desde la base de datos tras loguearse y realiza el ruteo correspondiente.

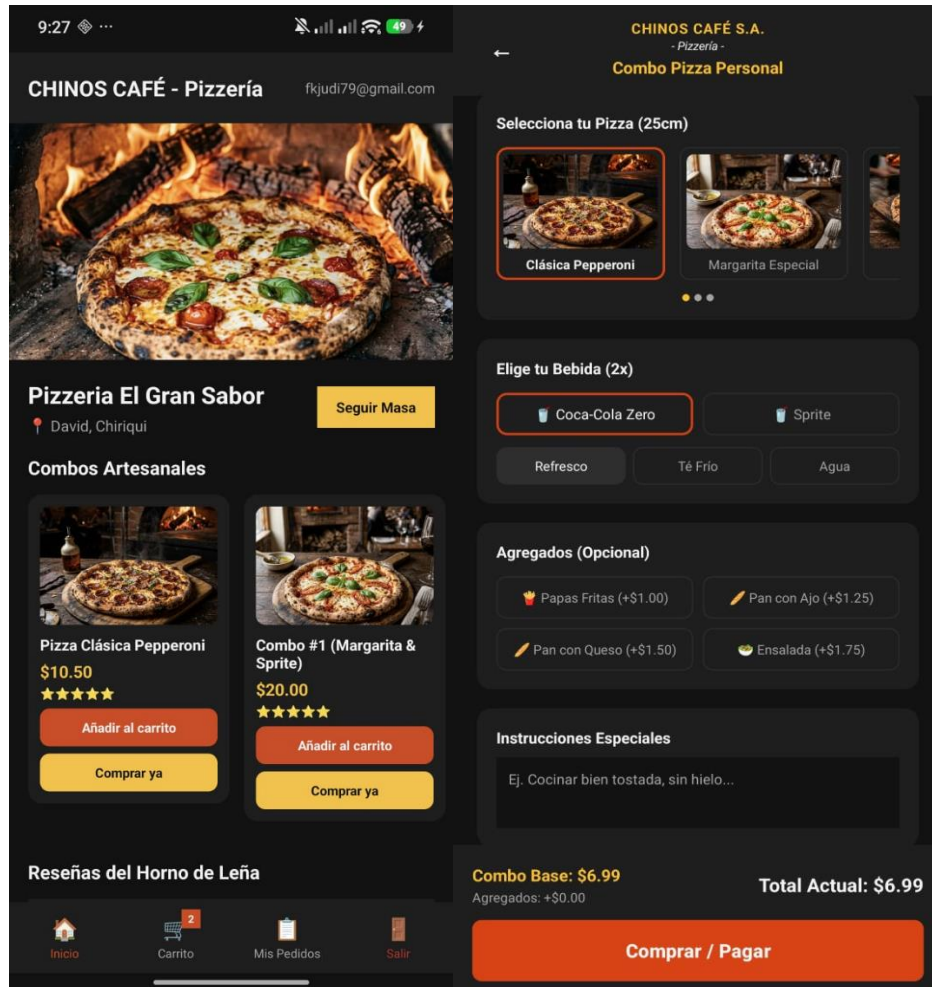


- **Registro:** Formulario con iconos vectoriales personalizados (silueta, cédula, sobre, candado) y casilla obligatoria de aceptación de términos y condiciones. Los datos se enlazan con SharedPreferences para saludar al cliente por su nombre real.



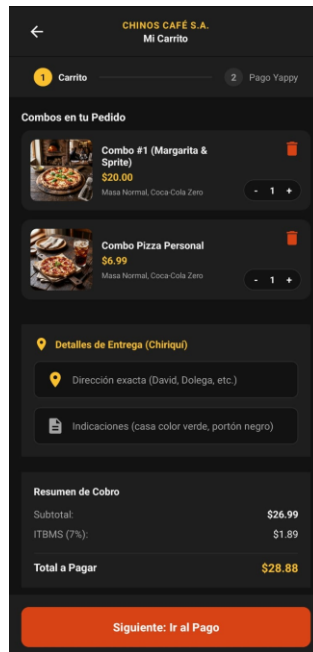
Personalizador Interactivo:

- Selector horizontal con tarjetas reactivas que se iluminan al seleccionarse y actualizan un indicador de páginas de 3 puntos dorados.
- Chips interactivos para bebidas (Coca-Cola Zero / Sprite) y grid de acompañamientos (Papas Fritas, Dedos de Queso, Pan con Ajo) con desglose dinámico e instantáneo de la factura en el panel inferior.



Carrito / Cesta de Compras:

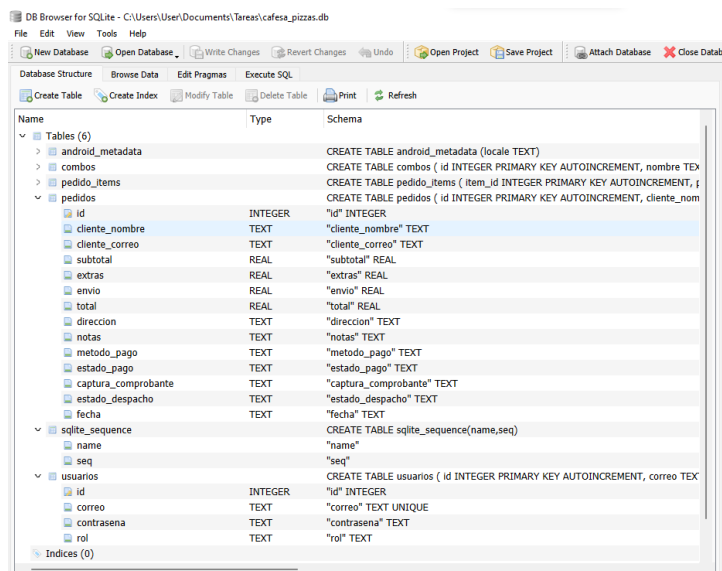
- Tarjetas con miniatura del combo, ingredientes y precio.
- Selector en pastilla (- 1 +) para modificar cantidades al vuelo y botón de eliminar (papelera).
- Cálculo matemático exacto de Subtotal, ITBMS (7%) y Total.



Fase 2: Gestión CRUD Local (SQLite)

Esquema Relacional (DatabaseHelper.kt):

- usuarios: Almacena id, correo, contraseña y rol (Administrador, Cliente, Operario).
- combos: Catálogo de pizzas y platos. Campos: id, nombre, descripción, precio, estado (Disponible/No Disponible), ingredientes y logo (nombre del recurso o URI).
- pedidos: Tabla de transacciones con id, cliente, correo, subtotal, extras (ITBMS), envío, total, dirección, notas, método de pago, estado de pago, comprobante, estado de despacho y fecha.
- pedido_items: Detalle de cada combo adquirido en un pedido, enlazado mediante clave foránea a la tabla principal.

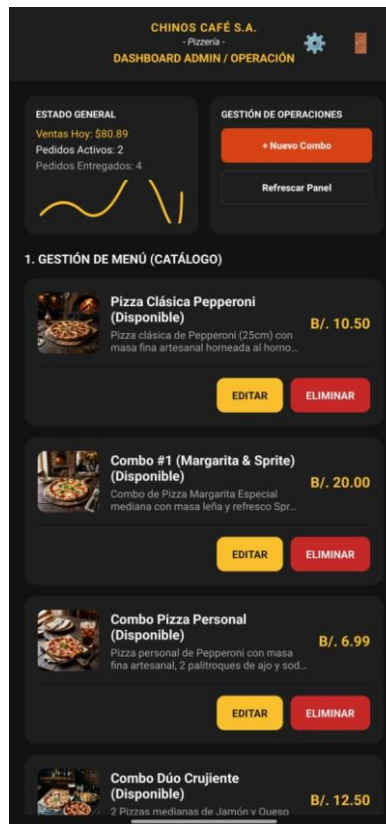


Envío de Datos:

- ❓ Failed to render LaTeX: KaTeX parse error: Expected 'EOF', got '#' at position 16: 10.50).
- *Combo #1 (Margarita & ...10.50), *Combo #2 (Margarita & Sprite)* (20.00), entre otros.
- Inserción por defecto de los usuarios evaluadores: Administrador (rbseiya7@gmail.com).

CRUD de Combos de Pizza:

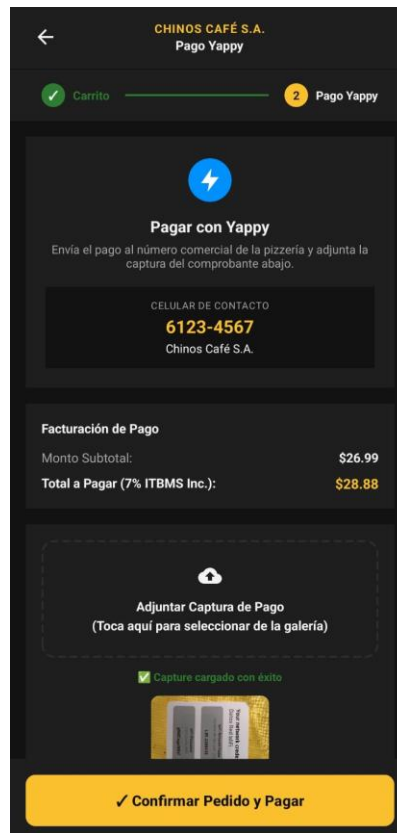
- El administrador cuenta con formularios dinámicos para añadir, editar o eliminar combos.
- Validación Estricta: Al crear un combo, es obligatorio subir una fotografía desde la galería del dispositivo (Intent.ACTION_OPEN_DOCUMENT con persistencia de permisos URI).



Fase 3: Pago Yappy y Tracking de Pedidos

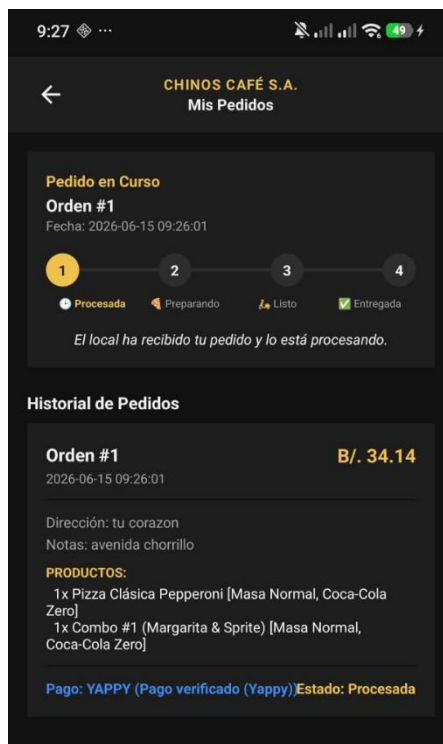
Pasarela de Pago Yappy:

- Selección de método de pago Yappy.
- Campo obligatorio para adjuntar la captura del comprobante desde el almacenamiento del dispositivo. Si el usuario selecciona Yappy, el sistema le impide finalizar la compra si no carga un archivo.



Seguimiento del Pedido Actual (Mis Pedidos):

- Creación de un Stepper Horizontal de 4 etapas pasivas fijos para el cliente: Procesada, Preparando, Listo, y Entregada.
- Consultas de Solo Lectura (GET): La aplicación del cliente realiza consultas periódicas (polling) a la base de datos local cada 3 segundos en segundo plano, actualizando los colores del stepper y el texto descriptivo de forma asíncrona sin permitir que el cliente altere los estados.



Fase 5: Flujo de Notificaciones de Correo

Paso 1: Acción de Checkout (Cliente)

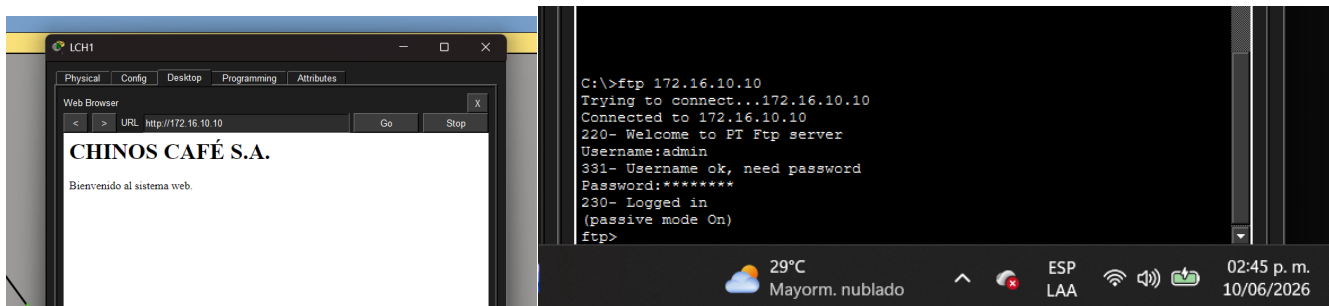
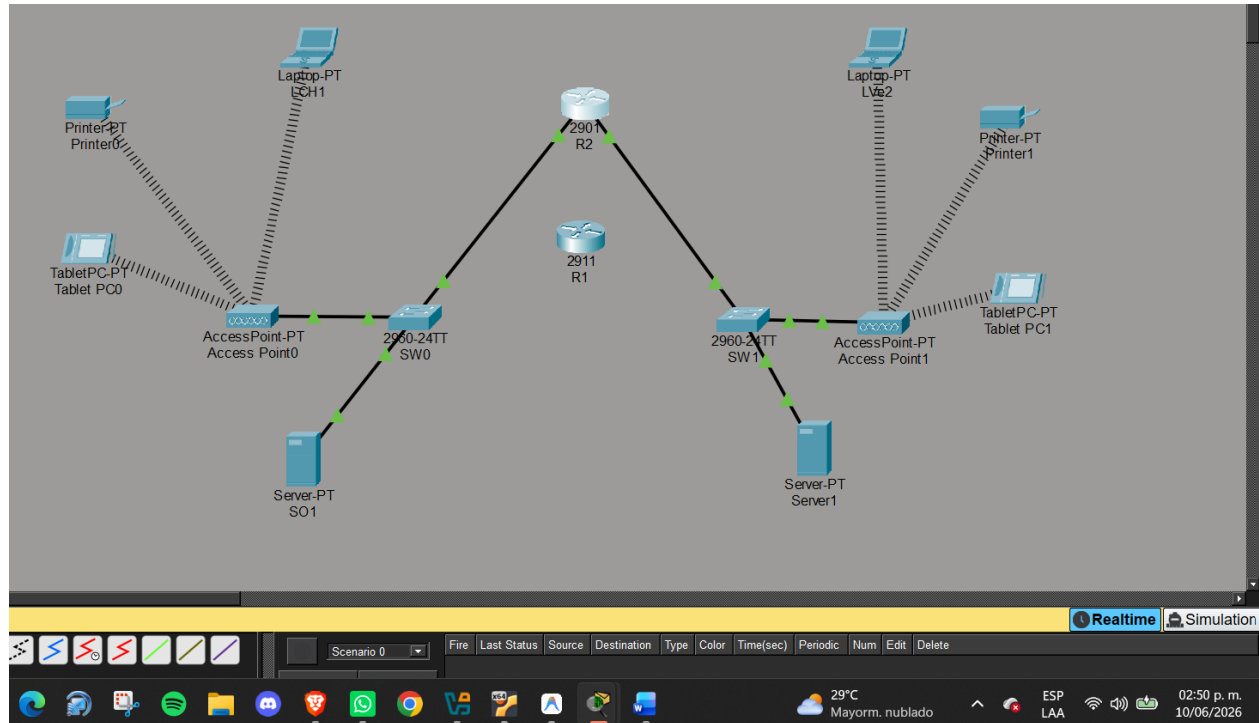
- El cliente presiona "Pagar".
- La orden se guarda localmente en SQLite con el estado Pendiente (despacho) y Pendiente de verificación (pago).
- La aplicación móvil sincroniza el pedido al endpoint /sync/pedido del servidor backend.
- El servidor guarda la orden en la base de datos réplica y almacena todo el payload JSON de la compra en la columna json_datos de la tabla pedidos.
- El servidor envía exclusivamente un correo de alerta a la empresa (rbeseiya7@gmail.com) indicando que hay una nueva compra pendiente por verificar. No se envía correo al cliente ni se genera ningún archivo JSON físico en disco.

Paso 2: Procesamiento (Administrador)

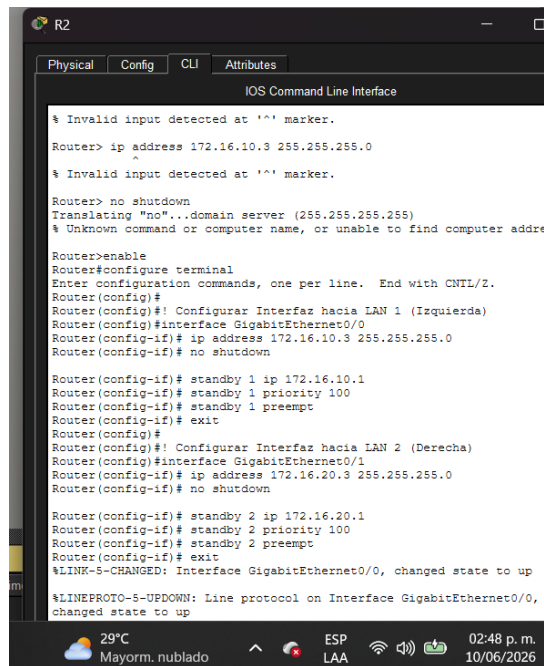
- El administrador ingresa a su Dashboard, verifica los detalles del pago de la orden y presiona el botón "PROCESAR" (disponible solo para pedidos en estado Pendiente).
- La app móvil actualiza el estado local de la orden a Preparando y el pago a Pago verificado (Yappy).
- La app llama al nuevo endpoint /sync/pedido/procesar en el servidor backend.
- El servidor:
- Recupera el payload completo del pedido consultando la columna json_datos en la base de datos espejo.
- Genera físicamente en disco los archivos orden_pizza_<id>.json y pago_yappy_<id>.json.
- Envía el correo con el recibo de compra final y el archivo JSON adjunto a la dirección de correo real registrada del cliente.
- Envía un correo de orden de trabajo al operario de horno (operario@cafesa.com) con el JSON de preparación adjunto.

Simulación de la red LAN

Validamos pings comprobamos el servidor web, confirmamos que al tumbar R1 la conexión sigue por R2-Secundario (HSRP), y verificamos que el FTP solo conecta desde la Laptop permitida y da Timed out en los otros dispositivos.



Entrar a la web del servidor local mediante la ip y entrar por ftp con su respectivo usuario y contraseña.



```
R2
Physical Config CLI Attributes
IOS Command Line Interface

% Invalid input detected at '^' marker.
Router> ip address 172.16.10.3 255.255.255.0
^
% Invalid input detected at '^' marker.
Router> no shutdown
Translating "no"...domain server (255.255.255.255)
% Unknown command or computer name, or unable to find computer address.
Router>enable
Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#
Router(config)#! Configurar Interfaz hacia LAN 1 (Izquierda)
Router(config)#interface GigabitEthernet0/0
Router(config-if)# ip address 172.16.10.3 255.255.255.0
Router(config-if)# no shutdown

Router(config-if)# standby 1 ip 172.16.10.1
Router(config-if)# standby 1 priority 100
Router(config-if)# standby 1 preempt
Router(config-if)# exit
Router(config)#
Router(config)#! Configurar Interfaz hacia LAN 2 (Derecha)
Router(config)#interface GigabitEthernet0/1
Router(config-if)# ip address 172.16.20.3 255.255.255.0
Router(config-if)# no shutdown

Router(config-if)# standby 2 ip 172.16.20.1
Router(config-if)# standby 2 priority 100
Router(config-if)# standby 2 preempt
Router(config-if)# exit
%LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to up
%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0,
changed state to up
```

La configuración del router principal R1 y el router de Respaldo R2

CREACIÓN DE SERVIDOR

Nuestro equipo configuró un entorno de servidor robusto y aislado en Linux para alojar los servicios de CHINOS CAFÉ S.A.

Infraestructura Base y Red

- **Servidor Web:** Instalamos y levantamos el servicio **Apache2** para servir la página web institucional y permitir la descarga de nuestra aplicación móvil (app.apk) [1].
- **Interfaz de Red:** Fijamos la tarjeta de red a la interfaz física del entorno de laboratorio (eth0).
- **Direccionamiento IP:** Configuramos el direccionamiento de forma estática asignando la IP fija 127.0.0.1 en la subred /1 (255.255.255.0), estableciendo el gateway en <http://172.16.10.55> y los servidores DNS globales en 8.8.8.8 para garantizar la estabilidad y evitar colisiones por DHCP.

```
ruben@Ruben21: ~  
Session Actions Edit View Help  
(ruben@Ruben21)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default ql  
en 1000  
    link/ether 08:00:27:15:07:20 brd ff:ff:ff:ff:ff:ff  
    inet 172.16.10.101/24 brd 172.16.10.255 scope global dynamic noprefixroute eth0  
        valid_lft 86361sec preferred_lft 86361sec  
    inet6 fe80::a00:27ff:fe15:720/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever
```

Gestión de Contenido e Identidad

- **Estructura Web:** Definimos el directorio raíz en /var/www/chinos_cafe/, aplicando propiedad al usuario del sistema www-data:www-data y permisos estrictos 644 sobre los archivos de código.
- **Maquetación y Estilos:** Diseñamos una interfaz responsiva con un esquema de colores institucional en naranja quemado y gris oscuro, utilizando fuentes modernas de Google Fonts (Oswald y Roboto).
- **Identidad Corporativa:** Acoplamos en el contenedor central de la página el logotipo profesional de la marca (un emblema rústico con horno de piedra y pizza artesanal), aplicando un estilo suavizado mediante propiedades de borde (border-radius) para una integración visual limpia.

COMANDOS USADOS

Configuración de Red e Interfaces

```
→ sudo nmcli connection modify "Wired connection 1" ipv4.method manual  
→ sudo nmcli connection modify "Wired connection 1" ipv4.addresses 172.16.10.0/24  
→ sudo nmcli connection modify "Wired connection 1" ipv4.gateway 172.16.10.101/24  
→ sudo nmcli connection modify "Wired connection 1" ipv4.dns "8.8.8.8,8.8.4.4"  
→ sudo nmcli connection down "Wired connection 1" sudo nmcli connection up "Wired connection 1"
```

Instalación y Maquetación del Entorno Web (Apache2)

```
→ sudo apt update && sudo apt install apache2 -y  
→ sudo mkdir -p /var/www/chinos_cafe/  
→ sudo nano /var/www/chinos_cafe/index.html  
→ sudo cp ~/Downloads/logo.png /var/www/chinos_cafe/logo.png  
→ sudo chown -R www-data:www-data /var/www/chinos_cafe/ sudo chmod 644  
/var/www/chinos_cafe/index.html sudo chmod 644 /var/www/chinos_cafe/logo.png
```

```

(ruben@Ruben21)-[~]
$ sudo mkdir -p /var/www/chinos_cafe
[sudo] password for ruben:

(ruben@Ruben21)-[~]
$ echo '<html><head><title>Chinos Café - Descarga nuestra App</title></head><body><h1>Bienvenido a CHINOS CAFÉ S.A.</h1><p>Descarga nuestra aplicación móvil de pedidos:</p><a href="app.apk" download>Descargar App APK</a></body></html>' | sudo tee /var/www/chinos_cafe/index.html
<html><head><title>Chinos Café - Descarga nuestra App</title></head><body><h1>Bienvenido a CHINOS CAFÉ S.A.</h1><p>Descarga nuestra aplicación móvil de pedidos:</p><a href="app.apk" download>Descargar App APK</a></body></html>

(ruben@Ruben21)-[~]
$ sudo touch /var/www/chinos_cafe/app.apk

(ruben@Ruben21)-[~]
$ sudo chown -R www-data:www-data /var/www/chinos_cafe

(ruben@Ruben21)-[~]
$ sudo chmod 755 /var/www/chinos_cafe

(ruben@Ruben21)-[~]
$ sudo chmod 644 /var/www/chinos_cafe/index.html /var/www/chinos_cafe/app.apk

```



CREACIÓN DE LA RÉPLICA DE LA BASE DE DATOS

Para soportar las transacciones y los pedidos de la aplicación sin comprometer la base de datos de producción, estructuramos un sistema de bases de datos relacionales en el servidor de la empresa.

Modelo y Despliegue

- **Motor de Base de Datos:** Implementamos el motor de base de datos relacional nativo en el servidor.
- **Arquitectura de Datos:** Creamos esquemas limpios para almacenar el menú, los registros de usuarios y el historial de pedidos de la pizzería.
- **Control de Acceso:** Restringimos el usuario administrativo por defecto y creamos credenciales específicas con privilegios mínimos para que la aplicación web pueda realizar consultas sin exponer la base de datos completa.

COMANDOS USADOS

```

→ sudo apt install mariadb-server mariadb-client -y
→ sudo systemctl enable mariadb
→ sudo systemctl start mariadb

```

→ sudo mysql -u root

```
(ruben@rubenzi)-[~]
$ python replication_server.py
[*] Base de datos réplica (MYSQL) inicializada correctamente.
* Serving Flask app 'replication_server'
* Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use
a production WSGI server instead.
* Running on all addresses (0.0.0.0)
* Running on http://127.0.0.1:5000
* Running on http://192.168.0.55:5000
Press CTRL+C to quit
* Restarting with watchdog (inotify)
[*] Base de datos réplica (MYSQL) inicializada correctamente.
* Debugger is active!
* Debugger PIN: 129-665-845
[!] Fallo al sincronizar combo 9: 1406 (22001): Data too long for column 'logo' at
row 1
192.168.0.30 - - [10/Jun/2026 14:21:43] "POST /sync/combo HTTP/1.1" 500 -
```

DEFENSA DEL SERVIDOR

Para mitigar los vectores de ataque y blindar la infraestructura de CHINOS CAFÉ S.A., nuestro grupo diseñó e implementó un esquema de seguridad perimetral y de aplicación basado en el principio de **Defensa en Capas**:

Capa 1: Seguridad (Port Knocking)

- **Mecanismo:** Instalamos y configuramos el demonio knockd para volver invisibles los puertos de administración 21 (FTP) y 22 (SSH).
- **Lógica de Bloqueo:** El cortafuegos iptables mantiene estos puertos cerrados por defecto ante cualquier escaneo de puertos (como un barrido de Nmap).
- **Secuencia Secreta:** Los puertos solo se abren durante una ventana dinámica de **15 segundos** únicamente para la IP cliente que envíe de forma consecutiva la ráfaga exacta de paquetes TCP a los puertos **7000:tcp**, **8000:tcp**, **9000:tcp**. Tras este lapso, las conexiones ya establecidas se mantienen seguras (ESTABLISHED,RELATED), pero el puerto vuelve a cerrarse externamente.

COMANDOS USADOS

- ```
→ sudo apt install iptables knockd -y
→ sudo nano /etc/knockd.conf
→ sudo nano /etc/default/knockd
→ sudo systemctl enable knockd sudo systemctl restart knockd

→ sudo iptables -A INPUT -m conntrack --state ESTABLISHED,RELATED -j ACCEPT sudo iptables -A INPUT -i lo -j ACCEPT
→ sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT
→ sudo iptables -A INPUT -p tcp --dport 22 -j DROP sudo iptables -A INPUT -p tcp --dport 21 -j DROP
```

## Capa 2: Cortafuegos de Aplicación Web (WAF)

- **Mecanismo:** Integramos el módulo **ModSecurity** en el servidor Apache y activamos el motor de bloqueo en modo activo (SecRuleEngine On).
- **Reglas de Protección:** Clonamos y desplegamos el repositorio oficial del **Core Rule Set de OWASP (CRS)** en la ruta `/usr/share/modsecurity-crs/`. Este conjunto de reglas inspecciona en tiempo real el contenido de cada petición HTTP entrante.

### COMANDOS USADOS

```
→ sudo apt install libapache2-mod-security2 -y
→ sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
 sudo nano /etc/modsecurity/modsecurity.conf
→ sudo rm -rf /usr/share/modsecurity-crs sudo git clone https://github.com
 /usr/share/modsecurity-crs
→ sudo cp /usr/share/modsecurity-crs/crs-setup.conf.example /usr/share/modsecurity-crs/crs-
 setup.conf
→ sudo nano /etc/apache2/mods-enabled/security2.conf
```

## Capa 3: Mitigación de DoS y Fuerza Bruta (`mod_evasive`)

- **Mecanismo:** Implementamos `mod_evasive` para monitorizar la tasa y frecuencia de las solicitudes HTTP hacia la web.
- **Automatización del Baneo:** Conectamos el módulo directamente con el firewall del sistema mediante la directiva `DOSSystemCommand`. Si una dirección IP excede los umbrales de ráfaga permitidos, el servidor ejecuta una regla automática en iptables que expulsa y bloquea por completo el tráfico de esa IP a nivel de red.

### COMANDOS USADOS

```
→ sudo apt install libapache2-mod-evasive -y
→ sudo nano /etc/apache2/mods-available/evasive.conf
```

## Capa 4: Ofuscación e Información Oculta

- Modificamos la configuración de seguridad global de Apache (`security.conf`) forzando las directivas `ServerTokens Prod` y `ServerSignature Off`. Con esto logramos eliminar las firmas del software y ocultar el número exacto de la versión de Linux/Apache ante cualquier consulta de reconocimiento externa.

### COMANDOS USADOS

```
→ sudo nano /etc/apache2/conf-available/security.conf
→ sudo apache2ctl configtest
→ sudo systemctl restart apache2
```

# ATAQUES A OTROS DISPOSITIVOS

## NMAP al Servidor dentro de la RED LAN Inalámbrica

Advanced IP Scanner

ArchivoVistaConfiguraciónAyuda

Explorar

172.16.10.0-200

Ejemplo: 192.168.0.1-100, 192.168.0.200

Buscar

| Estado | Nombre                                                         | IP            | Fabricante               | Dirección MAC   | Comentarios |
|--------|----------------------------------------------------------------|---------------|--------------------------|-----------------|-------------|
|        | 172.16.10.1                                                    | 172.16.10.1   |                          |                 |             |
|        | 172.16.10.20                                                   | 172.16.10.20  | Intel Corporate          | 5C5F679E5499    |             |
|        | 172.16.10.93                                                   | 172.16.10.93  |                          | B81EA48F66B9    |             |
|        | HTTP, Welcome to nginx! (nginx)                                |               |                          |                 |             |
|        | FTP (ftp)                                                      |               |                          |                 |             |
|        | 172.16.10.100                                                  | 172.16.10.100 |                          | 7E33B28D9323    |             |
|        | 172.16.10.120                                                  | 172.16.10.120 |                          | 849E5676420B    |             |
|        | 172.16.10.121                                                  | 172.16.10.121 |                          | 849E5676420B    |             |
|        | 172.16.10.123                                                  | 172.16.10.123 |                          | 7E33B28D9323    |             |
|        | 172.16.10.124                                                  | 172.16.10.124 | CHONGQING FUGUI ELECT... | A8934A91F8C9    |             |
|        | 172.16.10.127                                                  | 172.16.10.127 |                          | 76B77461261B    |             |
|        | 172.16.10.128                                                  | 172.16.10.128 |                          | 7E33B28D9323    |             |
|        | 172.16.10.129                                                  | 172.16.10.129 | Intel Corporate          | 5C5F679E5499    |             |
|        | 172.16.10.132                                                  | 172.16.10.132 |                          | 0E4AC71125DD    |             |
|        | 172.16.10.133                                                  | 172.16.10.133 | Intel Corporate          | 4889E71D8C1F    |             |
|        | 172.16.10.134                                                  | 172.16.10.134 |                          | 0E4AC71125DD    |             |
|        | 172.16.10.135                                                  | 172.16.10.135 |                          | 0E4AC71125DD    |             |
|        | 172.16.10.137                                                  | 172.16.10.137 |                          | D2C25F05A757    |             |
|        | 172.16.10.138                                                  | 172.16.10.138 |                          | 76B77461261B    |             |
|        | RICHARDG                                                       | 172.16.10.139 |                          | DC4546FA79F4    |             |
|        | 172.16.10.140                                                  | 172.16.10.140 |                          | D2C25F05A757    |             |
|        | HerreraRaul                                                    | 172.16.10.141 |                          | D4F32D719DDC    |             |
|        | 172.16.10.143                                                  | 172.16.10.143 |                          | DC4546FA79F4    |             |
|        | 172.16.10.144                                                  | 172.16.10.144 | Intel Corporate          | 4889E71D8C1F    |             |
|        | 172.16.10.145                                                  | 172.16.10.145 | Intel Corporate          | 4889E71D8C1F    |             |
|        | LAPTOP-A7R1LARO                                                | 172.16.10.147 |                          | B81EA48F66B9    |             |
|        | 172.16.10.148                                                  | 172.16.10.148 |                          | D4F32D719DDC    |             |
|        | 172.16.10.149                                                  | 172.16.10.149 |                          | 58CD:C985:EB:27 |             |
|        | 172.16.10.150                                                  | 172.16.10.150 |                          | 58CD:C985:EB:27 |             |
|        | 172.16.10.151                                                  | 172.16.10.151 |                          | 58CD:C985:EB:27 |             |
|        | DESKTOP-OG14KAK                                                | 172.16.10.152 | Intel Corporate          | 448500ED:E5:FE  |             |
|        | 172.16.10.153                                                  | 172.16.10.153 | CHONGQING FUGUI ELECT... | A8934A91F8C9    |             |
|        | 172.16.10.154                                                  | 172.16.10.154 | PCS Systemtechnik GmbH   | 080027:15:07:20 |             |
|        | HTTP, Chinos Café - Descarga nuestra App (Apache httpd 2.4.67) |               |                          |                 |             |

31 activo, 0 inactivo, 170 desconocido